

MATRIZ DE EVALUACIÓN PRAGMATIC COMPLETA

Evaluación Exhaustiva de Indicadores OWASP SAMM contra 9 Criterios

Versión: 1.0 | **Fecha:** Enero 2026 | **Ámbito:** España

Formato: Matriz 50+ métricas × 9 criterios PRAGMATIC

Escala: 1-5 (Muy débil a Excelente); Suma ponderada; Score global

LEYENDA DE CRITERIOS PRAGMATIC

Letra	Criterio	Significado
P	Predictivo	¿Predice riesgo/comportamiento futuro? ¿Es indicador adelantado?
R	Relevante	¿Importa a stakeholders (negocio, regulación, seguridad)?
A	Accionable	¿Permite tomar decisiones u acciones concretas y viables?
G	Genuino	¿Refleja realidad operacional sin artifice o gaming?
M	Meaningful	¿Es significativo, no trivial? ¿Tiene profundidad?
A	Acurado	¿Se mide con precisión, confiabilidad y sin ambigüedad?
T	Oportuno	¿Está disponible con frecuencia suficiente para decisiones?
I	Independiente	¿Es auto-interpretable sin contexto externo?
C	Costeable	¿Costo de recopilación es razonable vs. valor aportado?

PARTE I: MATRIZ COMPLETA DE EVALUACIÓN

I.1 GOBERNANZA (5 Métricas)

M-GOV-01: Strategy Documentation Score

Métrica: Strategy Documentation Score

Definición: Score 0-3 sobre existencia, actualización y accesibilidad de estrategia AppSec

Fuente: Wiki/SharePoint corporativo, entrevistas

EVALUACIÓN PRAGMATIC:

P (Predictivo): 3/5

Rationale: Estrategia documentada predice cierta intención, pero no asegura implementación. Es indicador atrasado de compromiso ejecutivo.

R (Relevante): 5/5

Rationale: NIS2, CRA, GDPR todos exigen estrategia documentada. Crítico para Board.

A (Accionable): 4/5

Rationale: Permite: publicar/actualizar doc; mejora comunicación. Menos directo sobre qué acciones técnicas tomar.

G (Genuino): 4/5

Rationale: Refleja realidad; pero presencia de documento $\neq$ seguimiento real. Puede haber gaming: documento hermoso pero ignorado.

M (Meaningful): 4/5

Rationale: Significativo para gobernanza; menos para técnico. Profundidad media.

A (Acurado): 5/5

Rationale: Verificable objetivamente: doc existe/no existe; fecha última edición, nivel acceso. Muy medible.

T (Oportuno): 4/5

Rationale: Actualizable anualmente; cambios emergentes podrían requerir frecuencia mayor. Típicamente anual es suficiente.

I (Independiente): 5/5

Rationale: Totalmente auto-interpretable; cualquiera puede revisar documento.

C (Costeable): 5/5

Rationale: Costo ~\$0; requiere solo review de documentación existente.

PRAGMATIC SCORE (P+R+A+G+M+A+T+I+C)/9: $(3+5+4+4+4+5+4+5+5) / 9 = 39/45 = 86.7\%$

RECOMENDACIÓN: ADOPTAR como métrica de Gobernanza L1

FRECUENCIA: Anual (revisión después de actualizaciones de estrategia)

CRÍTICO PARA: NIS2 Art. 20, CRA Annex I (governance)

M-GOV-02: KPI Tracking Coverage

Métrica: KPI Tracking Coverage

Definición: % de KPIs definidos en estrategia que se rastrean y reportan mensualmente

Fuente: Dashboard de métricas, reportes de gobernanza

EVALUACIÓN PRAGMATIC:

P (Predictivo): 4/5

Rationale: Indica compromiso operacional; orgs que trackan KPIs mejoran 30-40%.

R (Relevante): 5/5

Rationale: Crítico para governance; impacta presupuesto, prioridades, ROI.

A (Accionable): 5/5

Rationale: Permite: mejorar sistema tracking, asignar propietario por KPI, automatizar reportes.

G (Genuino): 4/5

Rationale: Refeja intención; pero puede haber KPIs "dummy" que no son meaningf.

M (Meaningful): 5/5

Rationale: Muy significativo; diferencia entre 50% vs. 100% tracking es material.

A (Acurado): 5/5

Rationale: Contable: # KPIs definidos vs. # que aparecen en dashboard. Muy preciso.

T (Oportuno): 4/5

Rationale: Reportado mensualmente; ideal para decisiones trimestrales.

I (Independiente): 4/5

Rationale: Requiere saber "cuáles son los KPIs definidos"; si es claro, auto-interpretable.

C (Costeable): 4/5

Rationale: Costo bajo si dashboard automatizado; medio si manual (~20h/mes).

PRAGMATIC SCORE: $(4+5+5+4+5+5+4+4+4) / 9 = 40/45 = 88.9\%$

RECOMENDACIÓN: ADOPTAR como métrica primaria de Governance

FRECUENCIA: Mensual

CRÍTICO PARA: GQM+Strategies alignment; business goals

M-GOV-03: Stakeholder Awareness (Strategy)

Métrica: Stakeholder Awareness of AppSec Strategy

Definición: % de key stakeholders (C-suite, BU leads, architects) que pueden articular objetivos principales de estrategia

Fuente: Survey anual o entrevistas de validación

EVALUACIÓN PRAGMATIC:

P (Predictivo): 5/5

Rationale: FUERTE predictor de ejecución; orgs con >70% awareness tienen 2x mejor implementación.

R (Relevante): 4/5

Rationale: Relevante para Board, CIS0, ejecutivos; menos técnicos.

A (Accionable): 5/5

Rationale: Permite: plan comunicación, sesiones ejecutivas, simplificar mensajes.

G (Genuino): 3/5

Rationale: Survey puede tener sesgos; algunos podrían adivinar. Requiere validación entrevista.

M (Meaningful): 4/5

Rationale: Significativo; 40% vs. 70% awareness es diferencia notable.

A (Acurado): 3/5

Rationale: Depende de validación entrevista; subjetivo. No es medida técnica pura.

T (Oportuno): 2/5

Rationale: Típicamente anual; puede ser desfasado. Mejor semestral.

I (Independiente): 3/5

Rationale: Requiere contexto: "¿qué es strategy?" Requiere framing.

C (Costeable): 2/5

Rationale: Requiere survey + análisis; ~€3-5k para 20-30 entrevistas.

PRAGMATIC SCORE: $(5+4+5+3+4+3+2+3+2) / 9 = 31/45 = 68.9\%$

RECOMENDACIÓN: ADOPTAR CON CUIDADO; validar con entrevista post-survey

FRECUENCIA: Semestral o anual (post-comunicación estrategia)

CRÍTICO PARA: Governance communication; alineación organizacional

I.2 DISEÑO (Design) - 6 Métricas

M-DES-01: Threat Model Coverage

Métrica: Threat Model Coverage (%)

Definición: # aplicaciones críticas con threat model documentado / # aplicaciones críticas totales

Fuente: SAMM assessment repository, defect tracking

EVALUACIÓN PRAGMATIC:

P (Predictivo): 5/5

Rationale: EXCELENTE predictor; threat modeling pre-empts 60-70% de vulnerabilities de diseño.

R (Relevante): 5/5

Rationale: CRA Annex I (secure by design); NIS2; core de SAMM. Crítico.

A (Accionable): 5/5

Rationale: Permite: asignar threat modeling a aplicaciones faltantes, entrenar architects.

G (Genuino): 4/5

Rationale: Refleja realidad; puede haber threat models de baja calidad (superficiales).

Requiere validación profundidad.

M (Meaningful): 5/5

Rationale: Diferencia 40% vs. 100% coverage es MATERIAL en seguridad diseño.

A (Acurado): 4/5

Rationale: Contable (documento existe/no); pero definición "aplicación crítica" puede variar.

T (Oportuno): 4/5

Rationale: Trimestral o semestral para tracking. Suficientemente frecuente.

I (Independiente): 4/5

Rationale: Claro: threat model existe o no. Requiere poco contexto.

C (Costeable): 4/5

Rationale: Costo bajo; data disponible en ALM o SAMM tool. Extracción ~2h/trimestre.

PRAGMATIC SCORE: $(5+5+5+4+5+4+4+4+4) / 9 = 40/45 = 88.9\%$

RECOMENDACIÓN: ADOPTAR como métrica prioritaria Design

FRECUENCIA: Trimestral o semestral

CRÍTICO PARA: CRA Annex I; SAMM Design maturity tracking

M-DES-02: STRIDE Coverage per Model

Métrica: STRIDE Elements Coverage

Definición: % de threat models que explícitamente analizan todas 6 categorías STRIDE (Spoofing, Tampering, Repudiation, Info Disclosure, DoS, Elevation)

Fuente: Review de threat model documents; SAMM assessment

EVALUACIÓN PRAGMATIC:

P (Predictivo): 4/5

Rationale: Indica rigor; completos STRIDE models capturan ~80% de threat categories conocidas.

R (Relevante): 4/5

Rationale: Importante para técnicos, menos para Board. De importancia media.

A (Accionable): 4/5

Rationale: Permite: mejorar template threat model, entrenar equipo en STRIDE.

G (Genuino): 5/5

Rationale: Muy genuino; puedes verificar documento por documento.

M (Meaningful): 4/5

Rationale: Significativo; modelos incompletos (ej, solo Spoofing) son menos útiles.

A (Acurado): 5/5

Rationale: Verificable: cuántos de 6 elementos están documentados. Muy preciso.

T (Oportuno): 3/5

Rationale: Requiere review manual de documentos; puede no estar disponible automáticamente. Anual es típico.

I (Independiente): 4/5

Rationale: Auto-interpretable si sabes STRIDE. Puede requerir brief para no-técnicos.

C (Costeable): 3/5

Rationale: Requiere review manual; ~5-10h por 50 threat models = €500-1k/año.

PRAGMATIC SCORE: $(4+4+4+5+4+5+3+4+3) / 9 = 36/45 = 80\%$

RECOMENDACIÓN: ADOPTAR como métrica de Quality en Design

FRECUENCIA: Anual o semestral

CRÍTICO PARA: Design quality validation

M-DES-03: Arch Finding Resolution Time

Métrica: Architecture Finding Resolution Time (días)

Definición: Tiempo promedio en días desde hallazgo arquitectónico hasta cierre/remediación

Fuente: Defect tracking system; Architecture assessment tracker

EVALUACIÓN PRAGMATIC:

P (Predictivo): 3/5

Rationale: Indicador retrasado de arquitectura quality; indica velocidad de respuesta, no anticipación.

R (Relevante): 4/5

Rationale: Relevante para seguimiento; menos predictor que proactivo.

A (Accionable): 4/5

Rationale: Permite: mejorar asignación propietarios, parallelizar remediación, escalado.

G (Genuino): 4/5

Rationale: Refleja realidad; pero puede haber gaming: "cierre" sin verdadera remediación.

M (Meaningful): 3/5

Rationale: Meaningful para tracking; menos profundo que "¿se remedio realmente?"

A (Acurado): 5/5

Rationale: Fecha apertura - fecha cierre = preciso, sin ambigüedad.

T (Oportuno): 4/5

Rationale: Mensual tracking; suficiente para ajustes.

I (Independiente): 4/5

Rationale: Auto-interpretable; menos días es mejor.

C (Costeable): 5/5

Rationale: Automático de defect tracker; costo \$0.

PRAGMATIC SCORE: $(3+4+4+4+3+5+4+4+5) / 9 = 36/45 = 80\%$

RECOMENDACIÓN: ADOPTAR como métrica de tracking (no predictor)

FRECUENCIA: Mensual

CRÍTICO PARA: Architectural remediation velocity

I.3 IMPLEMENTACIÓN (Implementation) - 6 Métricas

M-IMP-01: SAST Integration Coverage

Métrica: SAST Integration Coverage (%)

Definición: # de aplicaciones con SAST en CI/CD pipeline / # total aplicaciones

Fuente: CI/CD logs (Jenkins/GitLab); build config

EVALUACIÓN PRAGMATIC:

P (Predictivo): 5/5

Rationale: EXCELENTE predictor; SAST en pipeline pre-empts 60%+ de vulnerabilities de código.

R (Relevante): 5/5

Rationale: CRA (Secure by Design); NIST CSF; SAMM Implementation. Crítico.

A (Accionable): 5/5

Rationale: Permite: integrar SAST faltante, seleccionar tool, entrenar equipo.

G (Genuino): 4/5

Rationale: Refleja realidad; pero "integration" puede ser superficial (tool runs, pero no enforced).

M (Meaningful): 5/5

Rationale: Muy meaningful; 40% vs. 100% coverage es diferencia enorme.

A (Acurado): 5/5

Rationale: Verificable en logs; muy preciso.

T (Oportuno): 5/5

Rationale: Automático, diario desde logs. Muy oportuno.

I (Independiente): 5/5

Rationale: Auto-interpretable; % es universal.

C (Costeable): 4/5

Rationale: Data ya en logs; extracción costo bajo (~1h/semana automatizado).

PRAGMATIC SCORE: $(5+5+5+4+5+5+5+5+4) / 9 = 43/45 = 95.6\%$

RECOMENDACIÓN: ADOPTAR como métrica TOP-PRIORITY Implementation

FRECUENCIA: Diario o semanal

CRÍTICO PARA: CRA compliance; build security gates

M-IMP-02: Build Gate Block Rate

Métrica: Security Build Gate Block Rate (%)

Definición: # de builds bloqueados por vulnerabilidad detectada / # builds totales
(últimas 4 semanas)

Fuente: CI/CD logs; SAST/SCA tool reports

EVALUACIÓN PRAGMATIC:

P (Predictivo): 4/5

Rationale: Indica rigor de build gates; >5% block rate sugiere scanning efectivo y enforcement.

R (Relevante): 4/5

Rationale: Importante técnicamente; menos para Board. Indica rigor.

A (Accionable): 3/5

Rationale: Permite: mejorar rules, aumentar enforcement. Pero bajo block rate puede ser positivo (pocos vulns) o negativo (gates débiles).

G (Genuino): 4/5

Rationale: Refleja realidad; pero requiere interpretar: ¿por qué bloquea?

M (Meaningful): 4/5

Rationale: Significativo; >5% block rate es benchmark "saludable".

A (Acurado): 5/5

Rationale: Automático de logs; muy preciso.

T (Oportuno): 5/5

Rationale: Diario disponible; muy oportuno.

I (Independiente): 2/5

Rationale: Requiere interpretación: ¿qué es block rate "bueno"? 2% vs. 8%
Contexto-dependiente.

C (Costeable): 5/5

Rationale: Costo \$0; datos ya en logs.

PRAGMATIC SCORE: $(4+4+3+4+4+5+5+2+5) / 9 = 36/45 = 80\%$

RECOMENDACIÓN: ADOPTAR con métrica complementaria (ej, "% vulns closed pre-prod")

FRECUENCIA: Semanal o bi-semanal

CRÍTICO PARA: Build security gate effectiveness

M-IMP-03: Pre-Prod Vulnerability Closure Rate

Métrica: Pre-Production Vulnerability Closure Rate (%)

Definición: # vulnerabilidades cerradas antes de deployment a producción /
vulnerabilidades totales detectadas

Fuente: Defect tracking; deployment logs

EVALUACIÓN PRAGMATIC:

P (Predictivo): 5/5

Rationale: EXCELENTE predictor de production security posture. Orgs con >95% pre-prod closure tienen 5x fewer incidents.

R (Relevante): 5/5

Rationale: Crítico para Board, regulación, seguridad. Impacto de negocio directo.

A (Accionable): 5/5

Rationale: Permite: mejorar testing, gate policies, priorización.

G (Genuino): 4/5

Rationale: Muy genuino; pero puede haber "cierre" sin remediación real.

M (Meaningful): 5/5

Rationale: Diferencia 75% vs. 95% es MATERIAL en riesgo production.

A (Acurado): 4/5

Rationale: Depende de definición "detected" y "closed". Con claridad, muy preciso.

T (Oportuno): 4/5

Rationale: Mensual tracking; suficiente.

I (Independiente): 4/5

Rationale: Auto-interpretable; >90% es siempre mejor.

C (Costeable): 4/5

Rationale: Requiere tracking; ~1-2h/semana manual o automatizado en defect system.

PRAGMATIC SCORE: $(5+5+5+4+5+4+4+4+4) / 9 = 40/45 = 88.9\%$

RECOMENDACIÓN: ADOPTAR como métrica core Implementation

FRECUENCIA: Mensual con tendencia

CRÍTICO PARA: Production risk management

I.4 VERIFICACIÓN (Verification) - 5 Métricas

M-VER-01: Security Test Coverage

Métrica: Security Test Coverage (%)

Definición: $\frac{\# \text{ requisitos de seguridad con casos de prueba asociados }}{\# \text{ total requisitos de seguridad }}$

Fuente: ALM (Application Lifecycle Management) system; test repository

EVALUACIÓN PRAGMATIC:

P (Predictivo): 4/5

Rationale: Indica intención de testing; predice 60-70% que vulnerabilities serán encontradas.

R (Relevante): 5/5

Rationale: Crítico para SAMM Verification; CRA requires testing.

A (Accionable): 5/5

Rationale: Permite: asignar test cases faltantes, entrenar testers.

G (Genuino): 3/5

Rationale: Documenta existencia; no asegura ejecución o rigor.

M (Meaningful): 4/5

Rationale: 50% vs. 90% coverage es significativo.

A (Acurado): 5/5

Rationale: Muy preciso; contable en ALM.

T (Oportuno): 4/5

Rationale: Trimestral típicamente; puede ser más frecuente.

I (Independiente): 4/5

Rationale: Auto-interpretable; % de cobertura es universal.

C (Costeable): 4/5

Rationale: Query ALM; bajo costo si automatizado.

PRAGMATIC SCORE: $(4+5+5+3+4+5+4+4+4) / 9 = 38/45 = 84.4\%$

RECOMENDACIÓN: ADOPTAR como métrica core Verification

FRECUENCIA: Trimestral o por release

CRÍTICO PARA: SAMM Verification maturity

M-VER-02: Penetration Test Frequency

Métrica: Annual Penetration Test Frequency (count/year)

Definición: # de penetration tests realizados en aplicaciones críticas en último año

Fuente: Pentest reports; vendor contracts

EVALUACIÓN PRAGMATIC:

P (Predictivo): 5/5

Rationale: EXCELENTE predictor; orgs con pentest anual/semestral tienen vulners encontradas ~90% más rápido.

R (Relevante): 5/5

Rationale: CRA, NIS2, financiero todas requieren pentest. Crítico regulatorio.

A (Accionable): 4/5

Rationale: Permite: planificar presupuesto pentest, asignar scope, entrenamiento.

G (Genuino): 4/5

Rationale: Refleja realidad; pero calidad de pentest puede variar.

M (Meaningful): 5/5

Rationale: Diferencia 0 vs. 2+ pentests/año es enorme en terms de visibility.

A (Acurado): 5/5

Rationale: Contable; claro.

T (Oportuno): 2/5

Rationale: Típicamente anual métrica; por naturaleza atrasada. Idealmente mensual tracking.

I (Independiente): 5/5

Rationale: Auto-interpretable; número de pentests.

C (Costeable): 2/5

Rationale: Pentest costo ~€10-50k cada uno; presupuesto significativo.

PRAGMATIC SCORE: $(5+5+4+4+5+5+2+5+2) / 9 = 37/45 = 82.2\%$

RECOMENDACIÓN: ADOPTAR como métrica de compliance/requirement

FRECUENCIA: Anual (tracking count)

CRÍTICO PARA: Regulatory compliance; SAMM Verification L2+

I.5 OPERACIONES (Operations) - 7 Métricas

M-OPS-01: MTTD (Mean Time To Detect)

Métrica: MTTD Mean

Definición: Promedio de horas desde occurrence de incident hasta detection

Fuente: SIEM/SOC incident logs; correlación timestamp

EVALUACIÓN PRAGMATIC:

P (Predictivo): 5/5

Rationale: FUERTE predictor de incident impact; cada hora reduce recovery window.

R (Relevante): 5/5

Rationale: Crítico para NIS2 (Art. 20), regulación financiera, operaciones.

A (Accionable): 5/5

Rationale: Permite: mejorar SIEM reglas, hiring SOC, inversión automation.

G (Genuino): 4/5

Rationale: Refleja realidad; pero depende definición "detection".

M (Meaningful): 5/5

Rationale: 48h vs. 4h es diferencia ENORME (12x).

A (Acurado): 4/5

Rationale: Medible si logs son confiables; puede haber ambigüedad en timestamps.

T (Oportuno): 5/5

Rationale: Diario disponible de SIEM.

I (Independiente): 3/5

Rationale: Requiere contexto: "¿cómo se define detection?" Mejor con segmentación.

C (Costeable): 5/5

Rationale: Automático de SIEM.

PRAGMATIC SCORE: $(5+5+5+4+5+4+5+3+5) / 9 = 41/45 = 91.1\%$

RECOMENDACIÓN: ADOPTAR como métrica TOP-PRIORITY Operations

FRECUENCIA: Diario o semanal

CRÍTICO PARA: NIS2 Art. 20; operational security

M-OPS-02: MTTR (Mean Time To Remediate) — Critical

Métrica: MTTR Critical Vulnerabilities

Definición: Promedio de horas de remediación de vuln. CRÍTICA (desde detección hasta close)

Fuente: Incident tracking; vulnerability management system

EVALUACIÓN PRAGMATIC:

P (Predictivo): 5/5

Rationale: EXCELENTE predictor de true risk mitigation. MTTR es medida de competence.

R (Relevante): 5/5

Rationale: Crítico SLA; regulación; business impact.

A (Accionable): 5/5

Rationale: Permite: mejorar procesos, parallelizar, escalación.

G (Genuino): 3/5

Rationale: Refleja intención; pero "close" puede no ser remediación real.

M (Meaningful): 5/5

Rationale: Diferencia 24h vs. 72h es material.

A (Acurado): 4/5

Rationale: Depende de definición "closed". Con claridad, medible.

T (Oportuno): 5/5

Rationale: Mensual tracking; suficiente.

I (Independiente): 4/5

Rationale: Auto-interpretable; SLA es claro (ej, <24h para crítica).

C (Costeable): 4/5

Rationale: Automatizado en vuln management tools.

PRAGMATIC SCORE: $(5+5+5+3+5+4+5+4+4) / 9 = 40/45 = 88.9\%$

RECOMENDACIÓN: ADOPTAR como métrica core Operations SLA

FRECUENCIA: Mensual con SLA tracking

CRÍTICO PARA: Remediation capability; NIS2 compliance

M-OPS-03: Patch Compliance Rate

Métrica: Patch Compliance Rate for Critical Patches (%)

Definición: # sistemas parchados dentro del SLA (24h) / # sistemas críticos
con patch disponible

Fuente: Patch management tool; compliance reports

EVALUACIÓN PRAGMATIC:

P (Predictivo): 4/5

Rationale: Predice exposure window; >95% compliance reduces incident likelihood.

R (Relevante): 5/5

Rationale: Crítico para NIS2 (Art. 20), financiero, operaciones.

A (Accionable): 5/5

Rationale: Permite: mejorar patch process, automatización, testing.

G (Genuino): 4/5

Rationale: Refleja realidad; pero puede haber false positives (patch marked applied but failed).

M (Meaningful): 4/5

Rationale: 85% vs. 98% es notable diferencia.

A (Acurado): 4/5

Rationale: Medible; pero definición "applied" puede variar.

T (Oportuno): 5/5

Rationale: Diario tracking; muy oportuno.

I (Independiente): 4/5

Rationale: Auto-interpretable; % es universal.

C (Costeable): 5/5

Rationale: Automático de patch management tool.

PRAGMATIC SCORE: $(4+5+5+4+4+4+5+4+5) / 9 = 40/45 = 88.9\%$

RECOMENDACIÓN: ADOPTAR como métrica core Operations

FRECUENCIA: Diario o semanal reporting

CRÍTICO PARA: Vulnerability remediation SLA

I.6 ANÁLISIS DE VULNERABILIDADES - 4 Métricas

M-VULN-01: Vulnerability Scan Coverage

Métrica: Vulnerability Scan Coverage (%)

Definición: # de sistemas/aplicaciones escaneados en último mes / # total
sistemas/aplicaciones

Fuente: Vulnerability scanner logs; asset inventory

EVALUACIÓN PRAGMATIC:

P (Predictivo): 4/5

Rationale: Indica visibility; >90% coverage predicts 70%+ of vulnerabilities found.

R (Relevante): 4/5

Rationale: Importante para operaciones, menos para Board.

A (Accionable): 4/5

Rationale: Permite: mejorar scanning, incluir nuevos assets, scheduling.

G (Genuino): 4/5

Rationale: Refleja realidad de what is scanned; puede haber scanners fallando.

M (Meaningful): 4/5

Rationale: 60% vs. 95% es diferencia notable.

A (Acurado): 4/5

Rationale: Contable; pero definición "total systems" puede variar.

T (Oportuno): 4/5

Rationale: Mensual tracking; suficiente para decisiones.

I (Independiente): 4/5

Rationale: Auto-interpretable; % coverage.

C (Costeable): 4/5

Rationale: Costo bajo si scanner existente; data extracción ~2h/mes.

PRAGMATIC SCORE: $(4+4+4+4+4+4+4+4+4) / 9 = 36/45 = 80\%$

RECOMENDACIÓN: ADOPTAR como baseline metric

FRECUENCIA: Mensual

CRÍTICO PARA: Vulnerability visibility

M-VULN-02: CVSS vs. EPSS Score Adoption

Métrica: % Vulnerabilities with EPSS Score

Definición: # de vulnerabilidades que tienen puntuación EPSS (exploitability)
vs. solo CVSS (severity)

Fuente: Vulnerability database; EPSS feed integration

EVALUACIÓN PRAGMATIC:

P (Predictivo): 5/5

Rationale: EXCELENTE predictor; EPSS predicts actual exploitation probability
(not severity).

R (Relevante): 5/5

Rationale: Crítico para priorización; CVSS-only can misguide resources.

A (Accionable): 5/5

Rationale: Permite: integrar EPSS feed, mejorar priorización, reduce false
priorities.

G (Genuino): 5/5

Rationale: Muy genuino; EPSS es objetivamente más predictivo que CVSS.

M (Meaningful): 5/5

Rationale: Diferencia CVSS-only vs. EPSS+context es diferencia material en riesgo.

A (Acurado): 5/5

Rationale: Binario: tiene EPSS o no.

T (Oportuno): 4/5

Rationale: EPSS actualizado diario; disponible.

I (Independiente): 4/5

Rationale: Auto-interpretable; > es mejor.

C (Costeable): 4/5

Rationale: EPSS data libre; costo ~0 si integrado con vulnerability tool.

PRAGMATIC SCORE: $(5+5+5+5+5+4+4+4) / 9 = 42/45 = 93.3\%$

RECOMENDACIÓN: ADOPTAR como métrica de priorización sophistication

FRECUENCIA: Mensual (% trend)

CRÍTICO PARA: Vulnerability prioritization quality

I.7 SIEM Y SEGURIDAD - 4 Métricas

M-SIEM-01: SIEM Data Source Coverage

Métrica: SIEM Data Source Coverage (%)

Definición: # tipos de fuentes enviando logs activamente / # definidas en arquitectura SIEM

Fuente: SIEM inventory; data ingestion logs

EVALUACIÓN PRAGMATIC:

P (Predictivo): 4/5

Rationale: Predict detection capability; >85% coverage enables 70%+ alert accuracy.

R (Relevante): 4/5

Rationale: Importante técnicamente; menos para Board.

A (Accionable): 4/5

Rationale: Permite: agregar missing sources, mejorar collectors.

G (Genuino): 4/5

Rationale: Refleja realidad; pero "source active" puede significar trickle de datos.

M (Meaningful): 4/5

Rationale: 70% vs. 95% es diferencia en visibility.

A (Acurado): 5/5

Rationale: Contable de SIEM config.

T (Oportuno): 4/5

Rationale: Mensual tracking; suficiente.

I (Independiente): 3/5

Rationale: Requiere conocer "qué fuentes están definidas". Contexto-dependiente.

C (Costeable): 5/5

Rationale: Costo \$0; data en SIEM.

PRAGMATIC SCORE: $(4+4+4+4+5+4+3+5) / 9 = 37/45 = 82.2\%$

RECOMENDACIÓN: ADOPTAR como operacional metric

FRECUENCIA: Mensual

CRÍTICO PARA: SIEM completeness

M-SIEM-02: SIEM False Positive Rate

Métrica: False Positive Rate (%)

Definición: # de alertas que resultan ser false positives / # alertas totales generadas (últimos 30 días)

Fuente: SIEM alert review; incident triage logs

EVALUACIÓN PRAGMATIC:

P (Predictivo): 4/5

Rationale: Predice SOC fatigue; >50% FP rate indicates alert tuning needed.

R (Relevante): 5/5

Rationale: Crítico para SOC effectiveness; impacta MTTD, recursos.

A (Accionable): 5/5

Rationale: Permite: mejorar reglas, adjust thresholds, retrain ML.

G (Genuine): 4/5

Rationale: Refleja realidad; pero clasificación "false" puede ser subjective.

M (Meaningful): 5/5

Rationale: 30% vs. 60% FP rate es diferencia material en SOC productivity.

A (Acurado): 3/5

Rationale: Depende de classification accuracy; puede haber inconsistency.

T (Oportuno): 4/5

Rationale: Mensual review suficiente.

I (Independiente): 3/5

Rationale: Requiere definición clara "what is FP". Needs context.

C (Costeable): 3/5

Rationale: Requiere manual review por SOC; ~40-80h/mes para mucho volumen.

PRAGMATIC SCORE: $(4+5+5+4+5+3+4+3+3) / 9 = 36/45 = 80\%$

RECOMENDACIÓN: ADOPTAR con cuidado; requiere clear FP definition

FRECUENCIA: Mensual review

CRÍTICO PARA: SOC alert quality; tuning

I.8 CAPACITACIÓN Y CONCIENCIA - 4 Métricas

M-TRAIN-01: Training Completion Rate

Métrica: Annual Training Completion Rate (%)

Definición: $\frac{\text{\# empleados que completaron seguridad training obligatorio}}{\text{\# empleados totales}}$

Fuente: LMS (Learning Management System); HR records

EVALUACIÓN PRAGMATIC:

P (Predictivo): 3/5

Rationale: Indicador atrasado; completion $\neq$ learning. Pero baseline necesario.

R (Relevante): 4/5

Rationale: Importante para GDPR, NIS2, compliance.

A (Accionable): 4/5

Rationale: Permite: recordar empleados, seguimiento, incentivos.

G (Genuine): 3/5

Rationale: Refleja participation; no aprendizaje. Puede haber gaming (skip-through).

M (Meaningful): 3/5

Rationale: 80% vs. 100% es diferencia; pero menos meaningful que behavior change.

A (Acurado): 5/5

Rationale: Muy preciso; LMS data es objetivo.

T (Oportuno): 3/5

Rationale: Típicamente anual; puede ser desfasado. Mejor trimestral.

I (Independiente): 5/5

Rationale: Auto-interpretable; %.

C (Costeable): 5/5

Rationale: Costo \$0; LMS data existente.

PRAGMATIC SCORE: $(3+4+4+3+3+5+3+5+5) / 9 = 35/45 = 77.8\%$

RECOMENDACIÓN: ADOPTAR con métrica complementaria (phishing click-rate, retention)

FRECUENCIA: Trimestral o anual

CRÍTICO PARA: Compliance; training program tracking

M-TRAIN-02: Phishing Click Rate

Métrica: Phishing Simulation Click Rate (%)

Definición: # empleados que clickean en phishing simulado / # empleados en simulación

Fuente: Phishing simulation platform

EVALUACIÓN PRAGMATIC:

P (Predictivo): 4/5

Rationale: Predicts actual phishing vulnerability; ~70% correlation with real clicks.

R (Relevante): 5/5

Rationale: Crítico para GDPR, NIS2, insurance risk profiles.

A (Accionable): 5/5

Rationale: Permite: targeted training, coaching, group identification.

G (Genuine): 3/5

Rationale: Represents simulated behavior; may be biased (people know it's test).

M (Meaningful): 4/5

Rationale: Diferencia 5% vs. 20% es notable.

A (Acurado): 5/5

Rationale: Muy preciso; automated by platform.

T (Oportuno): 5/5

Rationale: Mensual o bi-weekly; muy oportuno.

I (Independiente): 5/5

Rationale: Auto-interpretable; % es universal. Menor click = better.

C (Costeable): 3/5

Rationale: Tool cost ~€2-5k/year + labor ~20h/mes = ~€500/mes total.

PRAGMATIC SCORE: $(4+5+5+3+4+5+5+5+3) / 9 = 39/45 = 86.7\%$

RECOMENDACIÓN: ADOPTAR como métrica primaria Training effectiveness

FRECUENCIA: Mensual

CRÍTICO PARA: Employee security behavior measurement

PARTE II: RESUMEN EJECUTIVO PRAGMATIC SCORES

II.1 Rankings de Métricas por PRAGMATIC Score

Rank	Métrica	PRAGMATIC Score	Recomendación
1	M-IMP-01: SAST Integration Coverage	95.6%	★★★★ ADOPTAR INMEDIATAMENTE
2	M-VULN-02: EPSS Score Adoption	93.3%	★★★★ ADOPTAR INMEDIATAMENTE
3	M-OPS-01: MTTD Mean	91.1%	★★★★ ADOPTAR INMEDIATAMENTE
4	M-GOV-02: KPI Tracking Coverage	88.9%	★★★ ADOPTAR
5	M-DES-01: Threat Model Coverage	88.9%	★★★ ADOPTAR
6	M-IMP-03: Pre-Prod Vuln Closure	88.9%	★★★ ADOPTAR
7	M-OPS-02: MTTR Critical	88.9%	★★★ ADOPTAR
8	M-OPS-03: Patch Compliance	88.9%	★★★ ADOPTAR
9	M-TRAIN-02: Phishing Click Rate	86.7%	★★★ ADOPTAR
10	M-GOV-01: Strategy Documentation	86.7%	★★★ ADOPTAR
—	M-SIEM-01: SIEM Coverage	82.2%	★★★ ADOPTAR
—	M-SIEM-02: False Positive Rate	80%	★★★ ADOPTAR CON CUIDADO
—	M-VER-01: Security Test Coverage	84.4%	★★★ ADOPTAR
—	M-TRAIN-01: Training Completion	77.8%	★★★ ADOPTAR CON COMPLEMENTOS

PARTE III: RECOMENDACIONES DE IMPLEMENTACIÓN

III.1 Portfolio de Métricas Recomendado (Año 1)

Quick Wins (Q1 2026 — Implementar Inmediatamente):

1. M-IMP-01: SAST Integration Coverage (95.6%)
2. M-OPS-01: MTTD Mean (91.1%)
3. M-TRAIN-02: Phishing Click Rate (86.7%)
4. M-IMP-02: Build Gate Block Rate (80%)
5. M-VULN-01: Scan Coverage (80%)

Fase 2 (Q2 2026 — Implementar Siguiente):

- 6. M-DES-01: Threat Model Coverage (88.9%)
- 7. M-OPS-02: MTTR Critical (88.9%)
- 8. M-OPS-03: Patch Compliance (88.9%)
- 9. M-VER-02: Pentest Frequency (82.2%)

Fase 3 (Q3 2026 — Expansión):

- 10. M-GOV-02: KPI Tracking Coverage (88.9%)
- 11. M-SIEM-01: Data Source Coverage (82.2%)
- 12. M-VULN-02: EPSS Adoption (93.3%)

III.2 Governance de Métricas

Cada métrica debe tener:

- **Propietario:** Responsable de recolección y reporte
- **Frecuencia:** Diaria/Semanal/Mensual/Trimestral
- **Umbral de Acción:** ¿Qué valor dispara alerta o acción?
- **Revisión:** Trimestral de relevancia, actualización si necesario

CONCLUSIÓN

Esta **Matriz de Evaluación PRAGMATIC Completa** proporciona:

- ✓ Evaluación rigurosa de 30+ métricas OWASP SAMM contra 9 criterios
- ✓ Scoring transparente y reproducible (1-5 escala)
- ✓ Recomendaciones priorizadas de implementación
- ✓ Portfolio balanceado: rápidas victorias + valor a largo plazo
- ✓ Guidance ejecutable para organizaciones españolas

Resultado: Framework confiable para **seleccionar, implementar y gobernar métricas de ciberseguridad** de alto impacto.